AegisAI — Executive Architecture Overview

Enterprise AI Security, Governance & Compliance Auditing Platform on Google Cloud

100% Serverless — Cloud Run Architecture
Zero Trust — Perimeter & Identity
Model Armor — Active AI Guardrails
Multi-Region nam5 — Encrypted Data Store

End-to-End Audit Lifecycle

1. **Request Submission** — User uploads AI blueprint & configs
2. **Perimeter Authorization** — IAP checks Google domain whitelist
3. **Evidence Extraction** — Engine extracts configs & scans GCP
4. **Model Armor Firewall** — Input screened for prompt injections
5. **Gemini Reasoning** — Scored against ISO 42001 & AISVS
6. **Evidence & Alerting** — Saved to nam5 DB; alerts to logging

Pillar 1 — Perimeter & Identity

Zero-Trust Access & Anti-DoW Quotas

Corporate Google Sign-In

Enterprise authentication via Google OAuth 2.0. Access is strictly locked to approved corporate email domains with zero personal account leakage.

Google Identity · Domain Allowlist

Cloud Identity-Aware Proxy (IAP)

Zero-Trust perimeter gate deployed directly in front of Cloud Run. Verifies user identity before any packet reaches the application backend.

Zero Trust Gate · No Public Backend

Built-In Anti-DoW Rate Limiter

Application-level defense against Denial-of-Wallet attacks. Enforces rolling window request quotas (30 req / 15 min) and concurrency controls.

Anti-DoW Defense · Concurrency Guard

Secret Manager Credentials

Centralized administrative token storage. Privileged tokens are resolved at container runtime via Secret Manager — zero hardcoded keys in code.

Keyless Secrets · Zero Static Keys

① Authorized Ingress

Pillar 2 — AegisAI Intelligence Core

Serverless Engine & Posture Scanner

Multi-Framework Audit Engine

Core intelligence engine that analyzes AI system architecture blueprints and data flows, automatically scoring against ISO 42001, OWASP AISVS, and EU AI Act.

Automated Audit · Cloud Run Serverless

AI-Focused GCP Posture Scanner

Audits live GCP infrastructure with focus on AI risks: scans training bucket IAM, CMEK on vector stores, and Vertex AI endpoint exposure (beyond generic SCC).

AI-Specific Posture · Live Environment

Resilient AI Model Router

Orchestrates model requests with automated retry logic, token budget controls, and seamless fallback between Gemini models during provider incidents.

High Availability · Automated Failover

Executive Compliance Dashboard

Interactive React dashboard delivering live Server-Sent Events (SSE) audit progression, interactive gap heatmaps, and downloadable executive PDF audit packs.

Real-Time UI · PDF Audit Export

② Sanitized AI Call

Pillar 3 — Google Vertex AI & Guardrails

Model Armor Firewall & Gemini Reasoning

Google Model Armor Firewall

Active bidirectional AI firewall operating in front of the model. Neutralizes prompt injections and jailbreak attacks in real-time before model invocation.

Inline Guardrails · Sub-15ms Latency

Gemini Multimodal Reasoning

Google Cloud flagship AI powering deep analytical reasoning over technical evidence. Supports Gemini 3.8 Flash, Pro, 2.5, or any configured model.

Supports Any Gemini Model · 3.8 Flash / Pro

Keyless Service Account (ADC)

Cloud Run runtime executes with dedicated service account credentials. Directly accesses Vertex AI via ambient ADC with zero stored API keys.

Keyless IAM · Ambient ADC

Enterprise Data Privacy Guarantee

Executed under Google Cloud Vertex AI commercial terms: customer prompts, evidence blueprints, and audit results are never used to train base models.

Zero Data Training · Private Tenancy

③ Store Evidence

Pillar 4 — Sovereign Storage & Audit Trail

Multi-Region Firestore & Cloud Logging

Firestore nam5 Multi-Region

Authoritative NoSQL storage running across geo-redundant US multi-regions. Fully encrypted at rest and in transit with high availability SLA.

nam5 Multi-Region · High Availability

Tamper-Proof Audit Repository

Immutable collection of evaluation reports (`audits`) containing verbatim technical citations, compliance scores (L1–L3), and remediation specifications.

Audits Collection · Immutable Evidence

Security Event Ledger

Real-time database collection (`security_alerts`) logging every intercepted prompt injection attempt, quota exceedance, and unauthorized access attempt.

Security Alerts · Active Threat Log

Google Cloud Logging Trail

Structured JSON operational log stream. Emits tamper-evident telemetry for every audit event, enabling complete traceability and enterprise SIEM export.

Tamper-Evident Trail · Cloud Logging

Real-Time SSE Result Stream to UI

Audited Regulatory Compliance Frameworks

- **ISO/IEC 42001:2023** — AI Management System — Phases 3, 4 & 5 (Design, Evaluation & Deployment)
- **OWASP AISVS v1.0** — AI Verification Standard — L1–L3 Controls & Adversarial Robustness
- **EU AI Act Ready** — High-Risk AI Governance — Transparency, Human Oversight & Risk Mitigation
- **Mexico NOM AI Ready** — National Standards — Data Sovereignty & Security Alignment

Google Cloud Enterprise Sovereignty & Privacy

- **100% Serverless** — Cloud Run compute scales to zero with zero idle cost
- **nam5 Multi-Region** — Geo-redundant storage with Google-managed at-rest encryption
- **Zero Data Training** — Prompts and evidence are never used to train base AI models
- **Keyless IAM Security** — Ambient Application Default Credentials (ADC) across services